Практическое занятие №2
Анализ рисков

Предмет: Обеспечение качества функционирования компьютерных систем
Выполнил: Богданов Роман Романович. Группа: ИС-41
Вариант А. Сервер интернет-магазина

1. Описание системы

Сервер интернет-магазина обслуживает сайт, на котором покупатели выбирают и заказывают товары. Покупатели оформляют заказы, а сотрудники обрабатывают их и передают на отправку. Администратор следит за работой сайта, учётными записями и обновлениями. Система хранит каталог, остатки, сведения о заказах и покупателях, а оплату подтверждает через платёжный сервис. Критически важны сохранность заказов, правильный учёт оплаты и доступность оформления покупки. Сервер работает круглосуточно, доступен через интернет и испытывает повышенную нагрузку во время распродаж.

2. Идентификация рисков

ID	Описание риска	Объект уязвимости	Угроза
R-01	Отказ диска сервера БД	Аппаратный, информационный	Отказ, потеря данных
R-02	Внезапное отключение питания	Аппаратный, программный	Отказ, потеря целостности
R-03	DDoS перегружает сайт	Программный, аппаратный	Блокирование
R-04	SQL-инъекция через ввод на сайте	Программный, информационный	Утечка, потеря целостности
R-05	Кража учётной записи администратора	Человеческий, информационный	Утечка, потеря целостности
R-06	Неудачное обновление сайта	Программный	Ошибка, сбой
R-07	Сотрудник случайно удаляет заказы	Человеческий, информационный	Ошибка, потеря целостности
R-08	Шифровальщик заражает сервер	Программный, информационный	Блокирование, потеря данных
R-09	Повторное уведомление об оплате создаёт второй заказ	Программный, информационный	Сбой, потеря целостности
R-10	Диск заполняется журналами и загрузками	Аппаратный, программный	Отказ, блокирование

3. Оценка рисков

Оценка учебная: статистика конкретного магазина не предоставлена. Рассматривается исходная система без перечисленных далее мер. Риск R = B × T, где B - вероятность, T - тяжесть последствий, обе оценки от 1 до 5.

Вероятность: 1 - менее 5%; 2 - 5-20%; 3 - 20-50%; 4 - 50-80%; 5 - более 80%. Для качественного сравнения условно принят горизонт один год. Тяжесть: 1 - минимальные неудобства; 2 - небольшие потери времени; 3 - заметные задержки; 4 - финансовые потери; 5 - потеря данных и серьёзные последствия.

ID	Вероятность и обоснование	Тяжесть и обоснование	R	Зона
R-01	3 - Диск изнашивается при постоянной работе.	5 - Без копии можно потерять заказы и данные покупателей.	15	Высокий
R-02	4 - При отсутствии резервного питания любое отключение прерывает работу.	4 - Магазин недоступен, незавершённые заказы требуют сверки.	16	Критический
R-03	4 - Публичный сайт без фильтрации доступен для массовых запросов.	4 - Покупатели не могут оформить заказы, продажи падают.	16	Критический
R-04	3 - Есть формы ввода, а проверка запросов до запуска не проведена.	5 - Возможны чтение и изменение данных покупателей и заказов.	15	Высокий
R-05	4 - Пароль без второго фактора могут получить через фишинг или повторное использование.	5 - Администратор имеет доступ к заказам, настройкам и данным клиентов.	20	Критический
R-06	3 - Изменения регулярно выпускаются, отдельной проверки пока нет.	4 - Ошибка оформления заказа останавливает продажи до отката.	12	Высокий
R-07	3 - При широких правах сотрудник может ошибиться при массовом действии.	5 - Удалённые заказы нельзя отправить без восстановления.	15	Высокий
R-08	3 - Необновлённый сервер и вложения создают пути заражения.	5 - Заказы и БД становятся недоступны, возможен длительный простой.	15	Высокий
R-09	3 - Платёжный сервис может повторять уведомления после сетевых ошибок.	4 - Возникают двойная отгрузка, возвраты и финансовые потери.	12	Высокий
R-10	4 - При постоянной работе данные растут, ротация журналов не настроена.	3 - Новые заказы не записываются до освобождения места.	12	Высокий

Зоны: 1-4 - низкий риск; 5-9 - средний; 10-15 - высокий; 16-25 - критический. В первую очередь рассматриваются R-05 (20), R-02 (16) и R-03 (16).

3. Меры по снижению рисков

Продолжение таблицы оценки: строки связаны по ID. Для каждого риска указаны тип меры, стратегия и ожидаемый результат.

ID	Мера	Тип	Стратегия	Ожидаемый эффект
R-01	RAID для доступности; отдельные резервные копии БД с проверкой восстановления.	Техническая, программная	Снижение	Сбой одного диска не останавливает работу; данные восстанавливаются из копии.
R-02	ИБП, контроль батареи, корректное завершение работы и транзакции при записи заказа.	Техническая, программная	Снижение	Краткие отключения переживаются без остановки; заказ сохраняется целиком либо отменяется.
R-03	Подключение анти-DDoS сервиса провайдера, лимиты запросов, кеш и оповещения.	Техническая, программная	Передача и снижение	Фильтрация передаётся провайдеру; лимиты уменьшают нагрузку. Ответственность магазина сохраняется.
R-04	Параметризованные запросы, минимальные права учётной записи БД, проверка форм.	Программная, организационная	Снижение	Ввод пользователя не исполняется как SQL; последствия ошибки ограничиваются правами.
R-05	Многофакторный вход, отдельные роли, уникальные пароли, обучение фишингу и аудит входов.	Программная, организационная	Снижение	Одного украденного пароля недостаточно; права и журнал ограничивают ущерб.
R-06	Тестовый стенд, проверки перед выпуском, резервная версия и план отката.	Программная, организационная	Снижение	Ошибки обнаруживаются заранее; неудачную версию можно быстро откатить.
R-07	Ограничение прав, подтверждение массового удаления, мягкое удаление и копии БД.	Программная, организационная	Снижение	Случайное удаление затруднено, записи можно восстановить.
R-08	Обновления, ограничение запуска программ, изоляция сервера, неизменяемые копии и тренировка восстановления.	Программная, организационная	Снижение	Снижается вероятность заражения; независимые копии позволяют восстановить данные.
R-09	Проверка подписи уведомления, уникальный ID платежа, идемпотентная обработка и сверка оплат.	Программная	Снижение	Повторное уведомление не создаёт повторный заказ и повторную отгрузку.
R-10	Ротация журналов, лимиты загрузок, контроль свободного места и оповещения.	Программная, организационная	Снижение	Место освобождается автоматически; администратор узнаёт о нехватке заранее.

4. Остаточный риск

Выбраны три риска с наибольшими исходными оценками. Ниже приведена прогнозная оценка после условного внедрения мер: реальное внедрение на сервере и измерение вероятностей в этой работе не проводились. Приемлемым для учебного примера считаем риск до 9 баллов, если есть ответственный, мониторинг и план восстановления.

ID и риск	Исходный R	Меры после условного внедрения	Новые B и T; R	Приемлемость
R-05. Кража аккаунта	4 × 5 = 20	Многофакторный вход, роли, уникальные пароли, обучение, аудит.	B=2; T=4 2 × 4 = 8	Условно да: средний. Контроль входов и отзыв доступа обязательны.
R-02. Отключение питания	4 × 4 = 16	ИБП, проверка батареи, безопасное выключение, транзакции.	B=2; T=3 2 × 3 = 6	Условно да: средний. Проверять батарею и восстановление заказов.
R-03. DDoS	4 × 4 = 16	Анти-DDoS провайдера, лимиты запросов, кеш, мониторинг.	B=2; T=3 2 × 3 = 6	Условно да: средний. Проверить пределы защиты и время реакции.

Почему оценки снизились

Для R-05 уменьшается вероятность успешного входа по украденному паролю, а разделение ролей ограничивает возможный ущерб. Для R-02 оценивается вероятность простоя и повреждения записи, а не самого отключения электричества. Для R-03 оценивается вероятность успешного блокирования сайта после защиты, а не частота попыток атак. При росте нагрузки и после инцидентов оценки нужно пересматривать.

5. Вывод

Самым опасным оказался захват учётной записи администратора: он позволяет менять настройки и получать доступ к данным. Следом идут отключение питания и DDoS, потому что они останавливают оформление заказов. После предложенных мер оценки этих трёх рисков снижаются до среднего уровня. В учебном примере такой уровень условно приемлем при постоянном контроле и готовности к восстановлению. Полностью риски не исчезают, поэтому нужны проверки резервных копий, ИБП и защиты от перегрузки. Дополнительно следует проверять права сотрудников и правильность обработки платежей, чтобы один сбой не приводил к потере заказа или повторной отгрузке.